



About the Client – All Ports Tours (APT)

All Ports Tours, the parent company of Croissant Cruises, is a mid-sized cruise operator that prides itself on delivering “Sunsets as a Service” to its passengers. The brand emphasizes modern, semi-autonomous cruise experiences where guests enjoy seamless entertainment, luxury amenities, and efficient operations while much of the ship’s navigation and core control systems are coordinated remotely from corporate Headquarters (HQ).

Following the economic downturn during the COVID-19 pandemic, the company reduced its investment in security assessments. As a result, Croissant Cruises has not undergone a penetration test in over five years. In that time, the fleet has adopted more automation, consolidated IT operations, and expanded remote command-and-control capabilities. This evolution raises the stakes for cybersecurity, making it critical to validate the resiliency of the current systems.

Organizational IT Structure

Onboard (ship-level, low-level IT staff)

- Ship IT Support Staff: Handle day-to-day troubleshooting for crew laptops, printers, POS systems, and passenger Wi-Fi. Often understaffed and juggling multiple responsibilities.
- Communications Technician: Maintains satellite communications (VSAT) and network equipment onboard. Sometimes defers patching due to operational demands.
- Bridge Operators / Technical Crew: Non-specialist crew who interact with navigation consoles and diagnostic tools. Provide valuable operational support but limited in cybersecurity expertise.

Onshore (HQ, high-level IT team)

- CISO & Cybersecurity Office: Define policies, approve engagements, and own risk.
- Fleet Operations Center: Remote operators who issue commands to autonomous systems and monitor ship telemetry.
- Corporate IT / DevOps Team: Maintain the Fleet Control Platform, cloud services, and centralized identity infrastructure.
- SOC/NOC Teams: Monitor logs from both HQ and the ships, providing centralized detection and response.

This structure creates a natural division: shipboard staff act as the first line of troubleshooting, while HQ IT provides centralized oversight and strategic security management.

Penetration Test Goals

- Validate control channel security between HQ and the semi-autonomous vessels — preventing spoofed commands or telemetry manipulation.
- Test network segmentation onboard (guest Wi-Fi, crew VLAN, operational technology) to confirm isolation of critical systems.
- Review update pipelines for the Fleet Control Platform and onboard systems to ensure protection against malicious updates.
- Assess identity and access management for shipboard IT staff and HQ administrators, focusing on credential theft and privilege escalation risks.
- Evaluate incident detection and response — can the SOC detect, investigate, and respond effectively to onboard-originating intrusions?
- Test resilience to social engineering (targeted phishing simulations for selected ship and HQ staff).

Out of Scope

- Third-party vendor systems such as bars, restaurants, and entertainment platforms are excluded from testing.
- Any live testing that could disrupt passenger safety, propulsion, or navigation during voyages is strictly prohibited.

Out-of-Scope Networks

- VDI
- VPN
- RIT Cyber Range
- Regional Host/University Environment

Out-of-Scope Tools

- Our Technology Partner's Deployment Tool (LaForge)
- Our Managed Security Service Provider's Log Collection Agent (SplunkUniversalForwarder)

The Challenge for Croissant Cruises

The brand's identity, "Sunsets as a Service", highlights its commitment to creating memorable guest experiences. But this slogan now carries an ironic double meaning: ensuring that sunsets remain an amenity for passengers — not the result of a catastrophic security failure.

By testing both shipboard weaknesses (limited IT staff, high workload, inconsistent patching) and HQ-level risks (remote control platforms, SOC visibility), this engagement aims to bring Croissant Cruises back into a mature, defensible cybersecurity posture fit for a modern autonomous fleet.

Q: Which kinds of operational and IT systems exist within the organization?

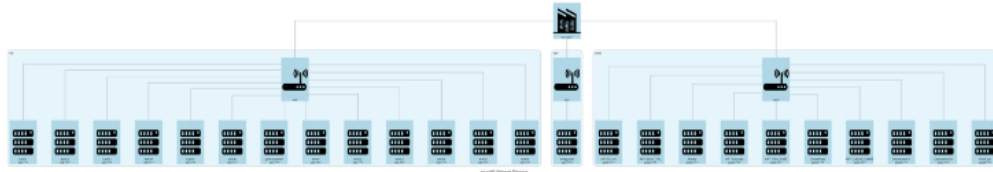
A: We operate a mix of traditional IT systems (email, identity management, and enterprise applications) alongside business-critical platforms that support our operations. These systems are secured with industry-standard controls and aligned with best practices to ensure confidentiality, integrity, and availability.

Q: Can we please get the business criticality for the services in APT Systems, for us to better align our reports.

A: All running services are critical for the business needs of APT and all due diligence should be taken to prevent the disruption of services.

Q: Will our team be provided with the topography of the network and/or a list of machines or IP addresses that are considered in-scope prior to the test?

A: Unfortunately, our head of Networking is out but we were able to dig this up.



Q: What technologies does your team use in their corporate network?

A: Our boats are our most critical assets – they are how we make money, and how we keep our passengers safe. Without them our business is unable to function. On the corporate side, we operate a mix of traditional IT systems (email, identity management, and enterprise applications) alongside business-critical platforms that support our operations.

Q: Are there any critical systems, workstations, or network segments that require special handling during testing due to operational sensitivity, compliance requirements, or potential for service disruption?

A: Our ships have a number of life-critical systems that are crucial to the health and safety of our employees and customers. Impacting these systems during a test will have significant consequences.